

Para fazer uma avaliação de segurança eficaz, você deve ser capaz de explicar as estratégias de defesa e ataque. É provável que suas responsabilidades estejam principalmente relacionadas à defesa de ativos, mas, para fazer isso, você deve ser capaz de explicar as táticas, as técnicas e os procedimentos (TTPs) dos autores de ameaças. Você também deve ser capaz de diferenciar os tipos e capacidades dos autores de ameaças e como podem explorar a superfície de ataque exposta pelas suas redes e seus sistemas.

Nesta lição, você vai fazer o seguinte:

- Comparar e contrastar atributos e motivações de diferentes tipos de autores de ameaças.
- Explicar vetores de ameaça e superfícies de ataque comuns.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Ao avaliar a postura de segurança da sua organização, você deve aplicar os conceitos de vulnerabilidade, ameaça e risco. O risco é uma medida da probabilidade e do impacto de um autor de ameaças conseguir explorar uma vulnerabilidade nos sistemas de segurança da sua organização.

Para avaliar esses fatores, você deve ser capaz de avaliar as fontes ou os autores de ameaças. Este tópico ajudará você a classificar e avaliar a motivação e as capacidades dos diferentes tipos de agentes de ameaças para que possa avaliar e mitigar os riscos de forma mais eficaz.

Objetivos abordados no exame:

- 2.1 Comparar e contrastar motivações e agentes de ameaças comuns.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

As equipes de segurança devem identificar como os sistemas podem ser atacados. Essas avaliações envolvem vulnerabilidade, ameaça e risco:

- **[[vulnerabilidade]]**: ponto fraco que pode ser desencadeado acidentalmente ou explorado de maneira intencional para causar uma violação de segurança. Exemplos de vulnerabilidades incluem hardwares ou softwares configurados ou instalados incorretamente, atrasos na aplicação e teste de patches de software e firmware, arquitetura de rede mal projetada, segurança física inadequada, uso de senha insegura e falhas de design em softwares ou sistemas operacionais. Fatores como o valor do ativo vulnerável e a facilidade de explorar a falha determinam a gravidade das vulnerabilidades.
- **[[Ameaça]]**: o potencial de algo ou alguém exploit (explorar) uma vulnerabilidade e violar a segurança. Uma ameaça pode ter uma motivação **[[intencional]]** ou ser **[[não intencional]]**. A pessoa ou coisa que representa a ameaça é chamada de *ator de ameaça* ou *agente de ameaça*. O caminho ou ferramenta utilizada por um ator de ameaça malicioso é um *vetor de ameaça*.
- **[[Risco]]** é o nível de perigo representado por vulnerabilidades e ameaças. Quando uma vulnerabilidade é identificada, o risco é calculado como a probabilidade de ela ser explorada por um autor de ameaças e o impacto que uma exploração bem-sucedida teria.

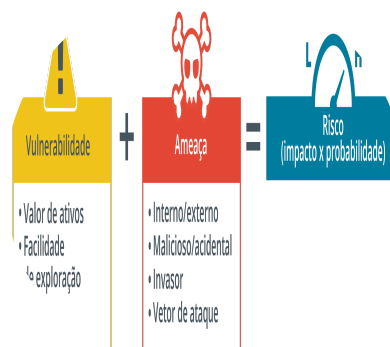


Figura 1. Relação entre vulnerabilidade, ameaça e risco.

Descrição

Um diagrama de blocos mostra que vulnerabilidade mais ameaça resulta em alto risco (impacto vezes probabilidade).



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Historicamente, as técnicas de cibersegurança dependiam da identificação de ameaças estáticas conhecidas, como vírus ou rootkits, cavalos de troia, botnets e explorações de vulnerabilidades específicas de software. É relativamente simples identificar e verificar esses tipos de ameaça utilizando softwares automatizados. Infelizmente, os opositores conseguiram desenvolver meios de contornar esse tipo de verificação baseada em assinatura.

A natureza sofisticada das ameaças modernas de cibersegurança requer a criação de perfis de tipos de autores de ameaças e comportamentos. Essa análise envolve a identificação dos atributos de localização, capacidade, recursos/financiamento e motivação dos autores de ameaças.

Interno/externo

[[Interno - externo]] refere-se ao grau de acesso que um ator de ameaça possui antes de iniciar um ataque. Um [[ator de ameaça]] externo não possui conta nem acesso autorizado ao sistema alvo. Uma ameaça externa mal-intencionada precisa se infiltrar no sistema de segurança usando acesso não autorizado, similar a arrombar e invadir um prédio ou hackear uma rede. Um invasor externo pode realizar um ataque remotamente ou no local. É o autor da ameaça que é definido como externo, não o método de ataque.

Por outro lado, um invasor interno/de dentro recebeu permissões no sistema. Normalmente, essa pessoa é um funcionário, mas uma ameaça interna também pode surgir de prestadores de serviços e parceiros de negócios.

Nível de sofisticação/capacidade

[[Nível de sofisticação - capacidade]] refere-se à habilidade de um ator de ameaça em utilizar técnicas e ferramentas avançadas de exploit. Um autor de ameaças menos capaz depende de ferramentas de ataque comercializadas amplamente disponíveis. Agentes mais habilidosos podem criar explorações em sistemas operacionais, softwares de aplicativos e sistemas de controle incorporados. No nível mais alto, um autor de ameaças pode usar ferramentas não cibernéticas, como ativos políticos ou militares.

Recursos/financiamento

Um alto nível de capacidade deve ser sustentado por [[recursos e financiamento]]. Grupos sofisticados de autores de ameaças precisam ser capazes de adquirir recursos, como ferramentas de ataque personalizadas e estrategistas, designers, programadores, hackers e engenheiros sociais qualificados. Os grupos de invasores mais capazes recebem financiamento de estados-nação e do crime organizado.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A *motivação* é o motivo pelo qual o invasor comete o ataque. Um autor de ameaças mal-intencionado pode ser motivado por ganância, curiosidade ou alguma insatisfação, por exemplo. As ameaças podem ser caracterizadas como estruturadas/direcionadas ou não estruturadas/oportunistas, dependendo do alcance do ataque.

Por exemplo, uma gangue que tenta roubar dados financeiros de clientes no sistema de banco de dados de uma empresa é uma ameaça estruturada e direcionada. Um hacker amador que envia uma variante do worm de e-mail “I Love You” para uma lista de e-mails roubada é uma ameaça oportunista e não estruturada.

Um autor de ameaças com motivação mal-intencionada é diferente de um autor de ameaças acidental ou não intencional. Um agente não intencional representa acidentes, descuidos e outros erros.

Para ajudar a analisar as motivações, primeiro é útil considerar as estratégias gerais que um invasor pode usar para atingir um objetivo:

- **[[Interrupção de serviço]]**: impede que uma organização funcione normalmente. Isso pode envolver um ataque ao site ou o uso de malware para bloquear o acesso a servidores e estações de trabalho de funcionários. A própria interrupção do serviço pode ser objetivo final, se a motivação do invasor for semear o caos ou se vingar. Ela pode ser usada como uma ameaça de chantagem ou como uma tática para alcançar outro objetivo estratégico.
- **[[Exfiltração de dados]]**: transfere uma cópia de algum tipo de informação valiosa de um computador ou rede sem autorização. Um autor de ameaças pode realizar esse tipo de roubo porque deseja o ativo de dados para si, porque pode explorar essa perda por meio de chantagem ou para vendê-lo a um terceiro.
- **[[Desinformação]]**: falsifica algum tipo de recurso confiável; por exemplo, pode alterar o conteúdo de um site, manipular mecanismos de pesquisa para injetar sites falsos ou usar bots para publicar informações falsas em sites de redes sociais.

Nota:

Você pode relacionar essas estratégias à maneira como elas afetam a tríade CIA: a exfiltração de dados compromete a confidencialidade, a desinformação ataca a integridade, e a interrupção do serviço tem como alvo a disponibilidade.

Motivações caóticas

Nos primórdios da Internet, muitos ataques de interrupção de serviço e desinformação eram realizados com o simples objetivo de semear o caos. Os hackers vandalizavam sites ou enviavam worms que paralisaram as redes da empresa por nenhum outro motivo além de ganhar crédito pelo hack.

Esse tipo de vandalismo sem um propósito maior é menos prevalente atualmente. Os invasores podem usar a interrupção do serviço e a desinformação em prol de fins políticos, e estados-nação podem usar isso para alcançar objetivos de guerra. Outro risco são os autores de ameaça motivados por vingança. Ataques por vingança podem ser realizados por um funcionário ou ex-funcionário ou por qualquer parte externa insatisfeita.

Motivações financeiras

Conforme o hacking e os malwares se tornaram mais sofisticados e mais comercializados, as oportunidades de usá-los para ganhos financeiros cresceram rapidamente. Se um invasor consegue roubar dados, pode vendê-los a outras partes. O invasor também pode usar um ataque para ameaçar a vítima com chantagem ou extorsão ou para cometer uma fraude:

- [[Extorsão]] é a exigência de pagamento para evitar a divulgação de informações. Um autor de ameaças pode ter roubado informações ou criado dados falsos que fazem parecer que o alvo cometeu um crime.
- Extorsão é a exigência de pagamento para evitar ou interromper algum tipo de ataque. Por exemplo, um autor de ameaças pode ter usado malware para bloquear o acesso aos computadores de uma empresa e exigir pagamento para desbloqueá-los.
- [[Fraude]] é a falsificação de registros. Uma fraude interna pode envolver a adulteração de contas para desviar fundos ou inventar dados de clientes para lavar dinheiro. Os criminosos podem usar a desinformação para cometer fraudes, como publicar notícias falsas para afetar o preço das ações de uma empresa, promover esquemas de pirâmide ou criar empresas falsas.

Motivações políticas

Neste caso, o autor da ameaça usa um ataque para provocar algum tipo de mudança na sociedade ou na governança. Isso pode envolver uma ampla gama de motivações:

- Um funcionário que atua como denunciante devido a alguma preocupação ética em relação ao comportamento da organização ou utiliza comportamento ilícito para obter informações com o objetivo de denunciar.
- Um grupo de campanha que interrompe os serviços de uma organização que acreditam estar agindo de forma contrária às suas crenças éticas ou filosóficas.
- Um estado-nação que usa a interrupção de serviços, exfiltração de dados ou desinformação contra entidades governamentais ou empresas de outro estado para alcançar objetivos de guerra.

Os estados-nação geralmente utilizam ataques de espionagem e desinformação uns contra os outros, estejam eles em guerra ou não. Na cibersegurança, a espionagem é um tipo de exfiltração de dados que visa descobrir segredos, em vez de vender os dados ou usar o roubo para chantagem.

Nota:

Há também a ameaça da espionagem comercial, em que uma empresa tenta roubar os segredos de um concorrente.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Dado o conhecimento das estratégias e motivações gerais, também pode ser útil avaliar o risco que os tipos ou perfis de autores de ameaças conhecidos representam para uma empresa.

Hackers

[[Hacker]]: descreve um indivíduo que tem as habilidades necessárias para obter acesso a sistemas de computador por meios não autorizados ou não aprovados. Originalmente, *hacker* era um termo neutro para um usuário que se destacava na programação de computadores e administração de sistemas de computadores. Hackear um sistema era um sinal de habilidade técnica e criatividade, mas isso gradualmente passou a estar associado a invasões de sistemas mal-intencionadas ou ilegais. Os termos [[não autorizado]] (anteriormente conhecido como black hat) e [[autorizado]] (anteriormente conhecido como white hat) são utilizados para distinguir essas motivações. Um hacker white hat sempre busca autorização para realizar testes de penetração em sistemas privados e proprietários.

Invasores amadores

Um [[atacante sem habilidades]] é alguém que utiliza ferramentas de hacker sem necessariamente compreender como elas funcionam ou ter a capacidade de criar novos ataques. Os ataques amadores podem não ter um alvo específico ou objetivo razoável além de chamar atenção ou provar habilidades técnicas.

Equipes de hackers e hacktivistas

A imagem histórica de um hacker é a de uma pessoa solitária, agindo por conta própria, com poucos recursos ou financiamento. Embora o “hacker solitário” continue sendo uma ameaça que deve ser levada em conta, os autores de ameaças agora provavelmente trabalham como parte de uma equipe ou grupo. O esforço colaborativo da equipe implica que esses autores de ameaças podem desenvolver ferramentas sofisticadas e novas estratégias.

Um *grupo hacktivista* utiliza armas cibernéticas para promover uma agenda política. [[Hacktivistas]] podem tentar usar a exfiltração de dados para obter informações confidenciais e divulgá-las para o público geral, realizar ataques de interrupção de serviço ou vandalizar sites para espalhar desinformação. Os grupos e empresas políticos, midiáticos e financeiros provavelmente são os que têm o maior risco de se tornarem alvos de hacktivistas, mas grupos de defesa ambiental e animal podem ter como alvo empresas de vários setores.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A maioria dos estados-nação desenvolveu conhecimentos de cibersegurança e usa armas cibernéticas para atingir objetivos militares e comerciais. O relatório APT1 da empresa de segurança Mandiant sobre unidades chinesas de ciberespionagem moldou a linguagem e a compreensão dos ciclos de vida dos ciberataques.

O termo [[ameaça persistente avançada (APT)]] foi criado para compreender o comportamento que fundamenta os tipos modernos de adversários cibernéticos. Em vez de designar sistemas infectados por um vírus ou cavalo de troia, uma APT refere-se à capacidade de um adversário de comprometer continuamente a segurança da rede — ou seja, obter e manter o acesso — usando diversas ferramentas e técnicas.

[[Atores de nação-estado]] têm sido implicados em diversos ataques, especialmente aos setores de energia, saúde e sistemas eleitorais. Os objetivos desses agentes são principalmente a desinformação e a espionagem para obter vantagem estratégica, mas há casos conhecidos de países — como a Coreia do Norte — que têm como alvo empresas para obter ganho financeiro.

Figura 1. Pesquisadores como a MITRE Corporation relatam as atividades do crime organizado e dos agentes de estados-nação.

ID	Name	Associated Groups	Description
G0018	admir@1337		admir@1337 is a China-based cyber threat group. It has previously been involved in attacks on financial, economic, and trade policy, typically using publicly available data, such as Personally identifiable information, as well as some non-public backdoors.
G0130	Aqua Security Team	Operation Golden Shield, Aqua Team, Operation Flying Dragon, Operation Golden Shield	Aqua Security Team is a group that has been active since at least 2010 and believed to be operating out of China. By 2014 Aqua Security Team transitioned from website defacement operations to malware-based cyber espionage campaigns targeting the US defense industrial base and various users of anti-censorship technologies.
G1006	ALLANTE	Palmetto Fusion	ALLANTE is a suspected Russian cyber espionage group that has primarily targeted the electric utility sector within the United States and United Kingdom. The group's tactics and techniques are reportedly similar to Stuxnet, although ALLANTE's technical capabilities have not exhibited disruptive or destructive abilities. It has been suggested that the group maintains a presence in ICS for the purpose of gaining understanding of processes and to maintain persistence.
G0138	Andorvil	Silent Chameleon	Andorvil is a North Korean state-sponsored threat group that has been active since at least 2008. Andorvil has previously been involved in operations which have included destructive attacks on Korean government agencies, military organizations, and domestic companies. They have also been involved in operations against ATMs, and Andorvil is notable for its use of a custom-built malware.

Captura de tela © 2023 The MITRE Corporation. Esta obra é reproduzida e distribuída com a permissão da MITRE Corporation.

Descrição

A página apresenta uma visão geral de diversos grupos atuando como crime organizado e atores de nação-estado. Uma tabela à direita lista o ID, o nome, os grupos associados e a descrição dos grupos.

Os agentes de estados trabalham mantendo uma certa distância do governo nacional, das forças armadas ou dos serviços de segurança que os patrocinam e protegem para que possam negar qualquer vínculo caso sejam descobertos.

É provável que se apresentem como grupos independentes ou até mesmo como hacktivistas. Eles podem realizar campanhas de desinformação sob bandeiras falsas, tentando colocar a culpa em outros Estados.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Em muitos países, o cibercrime ultrapassou o crime físico em termos de número de incidentes e perdas. O [[crime organizado]] pode operar pela Internet a partir de uma jurisdição diferente da de sua vítima, aumentando a complexidade da responsabilização judicial. Os criminosos buscam explorar qualquer oportunidade de lucro, porém as atividades mais comuns são fraude financeira — contra indivíduos e empresas — e chantagem/extorsão.

Acredita-se que a maior parte da espionagem seja realizada por agentes de estados, mas não é inconcebível que uma empresa desonesta possa usar a ciberespionagem contra seus concorrentes. Esses ataques podem ter como objetivo roubar ou atrapalhar os negócios de um concorrente ou prejudicar sua reputação. Os ataques de concorrentes podem ser facilitados por funcionários que mudaram de empresa recentemente e trazem consigo informações privilegiadas.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Muitos autores de ameaças operam externamente às redes que atacam. Um ator externo precisa invadir o sistema sem ter permissões legítimas. Uma [[ameaça interna]] (ou ameaça de insider) surge de um ator identificado pela organização e que possui algum tipo de acesso concedido. Dentro do grupo de ameaças internas, é possível distinguir agentes com privilégios permanentes, como funcionários, de agentes com privilégios temporários, como fornecedores e convidados.

Nota:

Há o caso complicado de ex-agentes internos, como ex-funcionários que agora trabalham em outra empresa, ou que foram demitidos e agora abrigam carregam uma insatisfação. Esses agentes podem ser classificados como ameaças internas ou tratados como ameaças externas com conhecimento interno e, possivelmente, algumas permissões residuais, se não houver controles eficazes de desligamento.

Os principais motivadores de um autor de ameaças interno mal-intencionado são vingança e ganho financeiro. Assim como nas ameaças externas, as ameaças internas podem ser oportunistas ou direcionadas. Um funcionário que planeja e executa uma campanha para modificar faturas e desviar fundos está lançando um ataque estruturado; um funcionário que tenta adivinhar a senha do banco de dados de salários algumas vezes após notar que o arquivo está disponível na rede está realizando um ataque oportunista. Você também deve avaliar a possibilidade de uma ameaça interna trabalhar em colaboração com um grupo ou agente de ameaças externo.

Nota:

Um denunciante é alguém com uma motivação ética para divulgar informações confidenciais. Embora isso possa ser de certa forma classificado como uma ameaça interna, é importante perceber que os denunciante que fazem divulgações protegidas, como denunciar fraudes financeiras por meio de um canal autorizado, não podem ser ameaçados ou rotulados de nenhuma maneira que pareça retaliatória ou punitiva.

As ameaças internas também podem surgir de fontes não intencionais. A [[ameaça interna não intencional ou inadvertida]] geralmente é causada por falta de conscientização ou descuido, como usuários que apresentam gerenciamento inadequado de senhas. Outro exemplo de ameaça interna não intencional é o conceito de shadow IT, no qual usuários adquirem ou introduzem hardware ou software de computador no ambiente de trabalho sem a autorização do departamento de TI e sem passar pelos processos de aquisição e análise de segurança. O problema da TI sombra é exacerbado pela proliferação de serviços em nuvem e dispositivos móveis, que são facilmente obtidos pelos usuários. A TI sombra gera uma nova superfície de ataque não monitorada para agentes mal-intencionados explorarem.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Entender os métodos pelos quais os autores de ameaças se infiltram em redes e sistemas é essencial para você avaliar a superfície de ataque das suas redes e implantar controles para bloquear vetores de ataque.

Objetivos abordados no exame:

- 2.2 Explicar vetores de ameaças comuns e superfícies de ataque.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

As superfícies de ataque são todos os pontos em que um invasor mal-intencionado pode tentar explorar uma vulnerabilidade. Qualquer local ou método em que um autor de ameaças possa interagir com uma porta da rede, aplicativo, computador ou usuário faz parte de uma superfície de ataque em potencial. Minimizar a superfície de ataque envolve restringir o acesso de modo que apenas alguns endpoints, protocolos/portas e serviços/métodos conhecidos sejam permitidos. Cada um desses pontos deve ser avaliado quanto a vulnerabilidades e monitorado para identificar invasões.

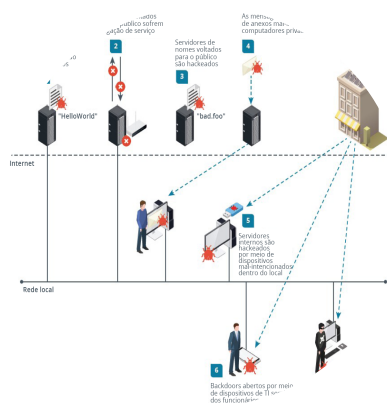


Figura 1. Avaliação da superfície de ataque.

Descrição

Os passos são os seguintes: 1.Servidores voltados para o público são invadidos em uma rede local. 2.Servidores voltados para o público conectados a uma rede local sofrem ataque de negação de serviço. 3.Servidores de nomes voltados para o público são invadidos. 4.O serviço de mensagens permite a transmissão de anexos maliciosos para computadores privados. 5.Servidores internos são invadidos por meio de dispositivos maliciosos levados ao local. 6.Backdoors são abertos por dispositivos de shadow IT utilizados por funcionários. 7.Insiders maliciosos fazem uso indevido de permissões.

Nota:

Uma organização tem uma superfície de ataque geral. Você também pode avaliar superfícies de ataque utilizando escopos mais limitados, como um único servidor ou computador, um aplicativo web ou identidades e contas de funcionários.

Para avaliar a superfície de ataque, você precisa considerar os atributos dos autores de ameaças que representam o maior risco para a sua organização. Por exemplo, a superfície de ataque de um agente externo deve ser muito menor do que a de uma ameaça interna.

Do ponto de vista de um invasor, cada parte da superfície de ataque representa um vetor potencial para tentar uma invasão. Um [[vetor de ameaça]] é o caminho que um ator de ameaça utiliza para executar uma exfiltração de dados, interrupção de serviço ou ataque de desinformação. Autores de ameaças sofisticados usam vários vetores. É provável que eles planejem uma campanha de várias fases, em vez de um único tipo de ataque para “arrombar e roubar”. Autores de ameaças altamente capazes conseguem desenvolver novos vetores. Isso significa que o conhecimento do invasor sobre a superfície de ataque da sua organização pode ser melhor do que o seu.

Nota:

Os termos “vetor de ameaça” e “vetor de ataque” geralmente são usados para se referir à mesma coisa. Algumas fontes distinguem o uso do termo “vetor de ameaça” para se referir à análise da possível superfície de ataque e “vetor de ataque” para analisar uma exploração executada com sucesso.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um [[software vulnerável]] contém uma falha em seu código ou design que pode ser explorada para contornar o controle de acesso ou causar a paralisação do processo. Geralmente, as vulnerabilidades podem ser exploradas apenas em circunstâncias muito específicas e costumam ser corrigidas rapidamente pelo fornecedor. No entanto, por causa da complexidade dos softwares modernos e da velocidade com a qual novas versões precisam ser lançadas no mercado, quase nenhum software está livre de vulnerabilidades. Além disso, uma organização pode não ter um sistema eficaz de gerenciamento de patches. Consequentemente, os softwares vulneráveis são um vetor de ameaça comumente explorado.

Um grande número de sistemas operacionais e aplicativos em execução nos appliances, servidores, clientes e redes em nuvem de uma empresa aumenta diretamente a superfície de ataque potencial. Essa superfície de ataque pode ser reduzida consolidando tudo isso em menos produtos e garantindo que a mesma versão de um produto seja implantada em toda a organização.

O impacto e as consequências de uma vulnerabilidade de software são variados. Como dois exemplos contrastantes, considere as vulnerabilidades que afetam o leitor de documentos PDF da Adobe em comparação com uma vulnerabilidade no software do servidor de segurança de transporte. O primeiro exemplo poderia dar ao autor da

ameaça acesso a uma rede corporativa por meio de uma estação de trabalho; o segundo poderia comprometer as chaves criptográficas usadas para fornecer serviços web seguros. Ambos são potencialmente de alto impacto por razões diferentes.

Sistemas e aplicativos sem suporte

[[Sistemas e aplicativos]] sem suporte são uma razão específica para que softwares vulneráveis fiquem expostos como vetores de ameaça. Um sistema sem suporte é aquele que não tem mais atualizações e patches desenvolvidos pelo seu fornecedor. A menos que a organização consiga corrigir o código defeituoso, esses serviços e aplicativos estarão altamente vulneráveis a explorações.

Nota:

Uma estratégia para lidar com aplicativos sem suporte que não podem ser substituídos é tentar isolá-los de outros sistemas. A ideia é reduzir as oportunidades de um invasor acessar o aplicativo vulnerável e executar o código de uma exploração. O uso do isolamento como substituto do gerenciamento de patches é um exemplo de controle de compensação.

Baseado no cliente ou sem agente

Os softwares de varreduras ajudam as organizações a automatizar a descoberta e classificação de vulnerabilidades de software. Essas ferramentas também podem ser usadas por agentes de ameaças como parte do reconhecimento de um alvo. Esses softwares de varredura podem ser implementados como um agente baseado no cliente. O agente é executado como um processo de varredura instalado em cada host e se reporta a um servidor de gerenciamento. Como alternativa, o produto de gerenciamento de vulnerabilidades pode usar técnicas sem agente para fazer uma varredura do host sem exigir nenhum tipo de instalação. A varredura sem agente é mais comumente usada no reconhecimento de autores de ameaças.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os softwares vulneráveis oferecem uma oportunidade para um agente de ameaças executar códigos mal-intencionados em um sistema. Para fazer isso, o agente deve ser capaz de executar o código de exploração no sistema ou em uma rede para acionar a vulnerabilidade. Uma técnica de exploração para qualquer vulnerabilidade de software pode ser classificada como remota ou local:

- **Remota** significa que a vulnerabilidade pode ser explorada por meio do envio de um código para o destino através de uma rede e não depende de uma sessão autenticada no sistema para ser executada.
- **Local** significa que o código de exploração deve ser executado por meio de uma sessão autenticada no computador. O ataque ainda pode ocorrer em uma rede, mas o agente precisa usar credenciais válidas ou sequestrar uma sessão existente para executá-lo.

Consequentemente, para minimizar os riscos de vulnerabilidades de softwares, os administradores devem reduzir a superfície de ataque, eliminando redes inseguras. Uma [[rede não segura]] é aquela que *não possui* os atributos de confidencialidade, integridade e disponibilidade:

- **Falta de confidencialidade:** os autores de ameaças podem espionar o tráfego de rede e recuperar senhas ou outras informações confidenciais. Também são descritos como *ataques de escuta*.
- **Falta de integridade:** os autores de ameaças podem conectar dispositivos não autorizados. Podem ser usadas para espionar o tráfego ou interceptá-lo e modificá-lo, executar serviços e aplicativos falsificados ou executar código de exploração em outros hosts de rede. São frequentemente descritos como *ataques on-path*.
- **Falta de disponibilidade:** os autores de ameaças podem realizar ataques de interrupção de serviço. Também são descritos como *ataques de negação de serviço (DoS)*.

Uma rede segura usa uma estrutura de controle de acesso e soluções criptográficas para identificar, autenticar, autorizar e auditar usuários, hosts e tráfego de rede.

Alguns vetores de ameaça específicos associados a redes não seguras são:

- **Acesso direto:** o autor da ameaça usa o acesso físico ao site para perpetrar um ataque. Exemplos podem incluir: obter acesso a uma estação de trabalho desbloqueada, usar um disco de inicialização para tentar instalar ferramentas maliciosas ou roubar fisicamente um PC, notebook ou unidade de disco.
- **Rede com fio:** um autor de ameaças com acesso ao local físico conecta um dispositivo não autorizado a uma porta de rede física e o dispositivo tem permissão para se comunicar com outros hosts. Isso potencialmente permite que o invasor inicie ataques de escuta, on-path e DoS.
- **Rede remota e wireless:** o invasor obtém credenciais para um acesso remoto, obtém uma conexão sem fio à rede ou ainda quebra os protocolos de segurança usados para autenticação. Uma outra possibilidade é que o invasor falsifique um recurso confiável, como um access point, e o use para realizar a coleta de credenciais, usando, em seguida, os detalhes da conta roubada para acessar a rede.
- **Acesso à nuvem:** muitas empresas agora executam uma parte ou todos os seus serviços de rede por meio de nuvens acessíveis pela Internet. O invasor só precisa encontrar uma conta, serviço ou host com credenciais fracas para obter acesso. É provável que o invasor tenha como alvo as contas usadas para desenvolver serviços na nuvem ou gerenciar sistemas de nuvem. Ele também pode tentar atacar o provedor de serviços de nuvem (CSP) como uma maneira de acessar o sistema da vítima.
- **Rede Bluetooth:** o autor da ameaça explora uma vulnerabilidade ou configuração incorreta para transmitir um arquivo malicioso para o dispositivo de um usuário através do protocolo de rede wireless da área pessoal Bluetooth.
- **Credenciais padrão:** o invasor obtém o controle de um dispositivo de rede ou aplicativo porque foi deixado com a configuração de senha padrão. As credenciais padrão provavelmente estarão publicadas na documentação de configuração do produto ou serão fáceis de descobrir.
- **Porta de serviço aberta:** o autor da ameaça consegue estabelecer uma conexão não autenticada com uma porta lógica de rede TCP ou UDP. O servidor executará um aplicativo para processar o tráfego de rede que

chega pela porta. O software pode ser vulnerável a um código de exploração ou à interrupção do serviço.

Nota:

Os servidores precisam abrir as portas necessárias para fazer com que os aplicativos e serviços de rede autorizados funcionem. No entanto, como parte da redução da superfície de ataque, os servidores não devem ser configurados para permitir o tráfego em portas desnecessárias. As redes podem usar princípios de design seguro, controle de acesso, firewalls e detecção de intrusão para reduzir a superfície de ataque.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

É [[algo]] superficialmente atraente ou interessante que faz com que seu alvo a queira, mesmo que possa estar escondendo algo perigoso, como um anzol. Em termos de segurança cibernética, quando o alvo abre o arquivo “isca”, o arquivo entrega um “anzol” — o payload do pacote malicioso — que normalmente dará ao autor da ameaça o controle sobre o sistema ou executará a interrupção do serviço.

Se o invasor não puder obter acesso suficiente para executar uma exploração remota ou local diretamente, uma isca pode enganar um usuário para facilitar o ataque. As mídias a seguir são comumente usadas como iscas:

- **Dispositivo removível:** o invasor esconde malware em um pen drive USB ou cartão de memória e tenta enganar funcionários, levando-os a conectar a mídia a um PC, notebook ou smartphone. Para algumas explorações, simplesmente conectar a mídia pode ser suficiente para executar o malware. Mais comumente, o invasor pode precisar que o funcionário abra um arquivo em um aplicativo vulnerável ou execute um programa de instalação.

Nota:

Em um ataque direto, o invasor simplesmente deixa pen drives infectados em escritórios, áreas de recepção ou estacionamentos, na expectativa de que pelo menos um funcionário pegue e o conecte a um computador.

- **Arquivo executável:** o autor da ameaça oculta o código de exploração em um arquivo de programa. Um exemplo é o malware cavalo de troia. Um cavalo de troia é um programa que parece ser algo gratuito e útil ou divertido, mas na verdade contém um processo que criará para o invasor um acesso backdoor ao computador.
- **Arquivos de documentos:** o ator de ameaça oculta código malicioso ao incorporá-lo em arquivos de processamento de texto e em formato PDF. Isso pode ser feito para aproveitar-se dos recursos de script ou simplesmente explorar uma vulnerabilidade no visualizador de documentos ou no software do editor.

- **Arquivos de imagem:** o ator de ameaça oculta código de exploit dentro de um arquivo de imagem que explora uma vulnerabilidade em navegadores ou softwares de edição de documentos.

Esses vetores expõem uma superfície de ataque grande e diversificada, desde os leitores USB e de cartões de memória instalados na maioria dos computadores até o software usado para navegar em sites e visualizar e editar documentos. A redução dessa superfície de ataque requer uma gestão de segurança de endpoint eficaz, usando controles como gestão de vulnerabilidades, antivírus, controle de execução de programas e detecção de intrusão.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Ao usar um arquivo de isca, o invasor precisa de um mecanismo para entregar o arquivo e uma mensagem que enganará um usuário, convencendo-o a abri-lo em seu computador. Consequentemente, quaisquer recursos que permitam o envio de mensagens diretas aos usuários da rede devem ser considerados como parte da possível superfície de ataque:

- **Email:** o invasor envia um arquivo malicioso em anexo por email ou por meio de qualquer outro sistema de comunicação que permita anexos. O invasor precisa usar técnicas de engenharia social para enganar ou persuadir o usuário a abrir o anexo.
- **Short Message Service (SMS):** o arquivo ou um link para o arquivo é enviado para um dispositivo móvel usando o gerenciador de mensagens de texto integrado ao firmware do smartphone e um protocolo chamado Signaling System 7 (SS7). O SMS e o protocolo SS7 estão associados a inúmeras vulnerabilidades. Além disso, é improvável que uma organização tenha qualquer capacidade de monitoramento para SMS, pois são operados pelo aparelho ou pelo provedor do cartão SIM (módulo de identificação do assinante).
- **Instant Messaging (IM):** existem muitas alternativas ao SMS que funcionam em dispositivos Windows, Android ou iOS. Elas podem oferecer suporte a mensagens de voz e vídeo, além de anexos de arquivos. A maioria desses serviços é protegida por criptografia e oferece muito mais segurança do que o SMS, mas eles ainda podem conter vulnerabilidades de software. O uso de criptografia pode tornar difícil para uma organização verificar se há ameaças em mensagens e anexos.
- **Web e mídias sociais:** malwares podem ser ocultados em arquivos anexados a postagens ou apresentados como downloads. Um invasor pode comprometer um site para que ele infecte automaticamente o software vulnerável do navegador (um download drive-by). As mídias sociais também podem ser usadas de forma mais sutil, como uma campanha de desinformação que convence os usuários a instalar um aplicativo “obrigatório” que é, na verdade, um cavalo de troia.

Nota:

As explorações mais potentes são as de zero clique. A maioria dos códigos de exploração baseados em arquivos deve ser aberta deliberadamente pelo usuário. No método zero clique, o simples ato de receber um anexo ou visualizar uma imagem em uma página web aciona a exploração.

Os vetores baseados em mensagens também podem ser explorados por um invasor para persuadir um usuário a revelar uma senha ou enfraquecer a configuração de segurança usando algum tipo de pretexto. Esse tipo de ataque pode ser perpetrado simplesmente fazendo uma chamada de voz para o usuário.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Uma [[cadeia de suprimentos]] é o processo de ponta a ponta de projetar, fabricar e distribuir bens e serviços até o cliente. Em vez de atacar diretamente o alvo, um invasor pode procurar maneiras de se infiltrar por meio de empresas na sua cadeia de suprimentos. Um exemplo notório disso é a violação de dados da Target, que foi feita por meio de credenciais mantidas pelo fornecedor de sistemas de construção da empresa.

O processo de garantir fontes confiáveis de equipamentos e software é chamado de gerenciamento de aquisições. No gerenciamento de aquisições, é útil distinguir vários tipos de relacionamentos:

- **Fornecedor:** obtém produtos diretamente de um fabricante para vender em grandes pacotes para outras empresas. Esse tipo de negociação é chamado de business to business (B2B).
- **Vendedor:** obtém produtos de fornecedores para vender a empresas de varejo (B2B) ou diretamente aos clientes (B2C). Um vendedor pode adicionar certa personalização e suporte direto.
- **Parceiro de negócios:** implica um relacionamento mais próximo em que duas empresas compartilham metas e oportunidades de marketing bastante alinhadas.

Por exemplo, a Microsoft é uma grande fabricante e fornecedora de software, mas não é viável que ela estabeleça relacionamentos diretos com todos os seus clientes em potencial. Para expandir seus mercados, ela desenvolve relacionamentos de parceria com fabricantes de equipamentos originais (OEMs) e parceiros de soluções. A Microsoft opera um programa de certificação e treinamento para seus parceiros, o que melhora o suporte ao produto e a conscientização sobre segurança.

Cada fornecedor e vendedor têm sua própria cadeia de suprimentos. Por exemplo, um fabricante e fornecedor de placas-mãe usará empresas para fabricar componentes de chips individuais. A cadeia de suprimentos se estende à distribuição, portanto, as empresas de entrega e os entregadores parceiros fazem parte dela.

Essa amplitude e complexidade da cadeia de suprimentos expõem as organizações a uma enorme superfície de ataque. Por exemplo, para que uma placa-mãe de computador seja confiável, as cadeias de suprimentos do fabricante de chips, do desenvolvedor de código de firmware, do revendedor OEM, da empresa de entrega parceira e da equipe administrativa responsável pelo provisionamento do dispositivo de computação ao usuário final devem ser todas confiáveis. Qualquer pessoa com tempo e recursos para modificar o firmware do computador pode criar acesso backdoor. O mesmo vale para qualquer hardware, software ou serviço de computador ou rede.

Estabelecer uma cadeia de suprimentos confiável para equipamentos e serviços de informática significa essencialmente negar aos atores mal-intencionados o tempo ou os recursos para modificar os ativos fornecidos.

Nota:

Para a maioria das empresas, o uso de fornecedores respeitáveis representará o melhor esforço prático para proteger a cadeia de suprimentos. Governos, serviços militares/de segurança e grandes empresas demandarão uma investigação mais aprofundada. Um cuidado especial deve ser tomado ao usar máquinas de segunda mão.

O setor de TI também depende do comércio de serviços, bem como de ativos físicos. Um provedor de serviços gerenciados (MSP) provisiona e oferece suporte para recursos de TI, como redes, segurança ou infraestrutura da Web.

Os MSPs são úteis quando uma organização considera mais barato ou mais confiável terceirizar toda ou parte da provisão de TI, em vez de tentar gerenciá-la diretamente. Do ponto de vista da segurança, esse tipo de terceirização é complexo, pois pode ser difícil monitorar o MSP. Os funcionários do MSP são todos fontes potenciais de ameaça interna.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

As pessoas — funcionários, prestadores de serviços, fornecedores e clientes — representam parte da superfície de ataque de qualquer organização. Coletivamente, eles são chamados de vetor humano. Uma pessoa com permissões no sistema é um alvo em potencial de técnicas manipuladoras de autores de ameaças conhecidas como engenharia social.

Ser capaz de comparar e diferenciar técnicas de engenharia social ajudará você a liderar o treinamento de conscientização de segurança e a desenvolver políticas e outros controles de segurança para mitigar esses riscos.

Objetivos abordados na prova

- 2.2 Explicar vetores de ameaças comuns e superfícies de ataque.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Opositores podem usar uma ampla gama de técnicas para comprometer um sistema de segurança. Um pré-requisito de vários dos tipos de ataques é obter informações sobre a rede e o sistema de segurança. Esse conhecimento não é armazenado apenas em discos de computador; ele também existe na mente de funcionários e prestadores de serviços. As pessoas que operam computadores e contas fazem parte da superfície de ataque conhecida como vetores humanos.

Engenharia social refere-se a métodos de obtenção de informações de alguém ou de induzi-lo a realizar alguma ação para o ator de ameaça. Isso também pode ser chamado de “hackear o humano”. Um autor de ameaças pode usar a engenharia social para coletar informações como forma de reconhecimento em preparação para uma invasão ou para efetuar uma invasão real obtendo credenciais de conta ou persuadindo o alvo a executar malware. Existem muitas estratégias diversas de engenharia social, mas para exemplificar, considere os seguintes cenários:

- Um autor de ameaças cria um arquivo executável que solicita a senha de um usuário da rede e, em seguida, registra todos os dados inseridos pelo usuário. O invasor envia por email o arquivo executável para o usuário informando que o usuário deve abrir o arquivo e fazer login na rede novamente para esclarecer alguns problemas de login que a organização vem enfrentando naquela manhã. Depois que o usuário cumpre a solicitação, o invasor ganha acesso às suas credenciais de rede.
- Um autor de ameaças entra em contato com o suporte técnico fingindo ser um representante de vendas remoto que precisa de ajuda para configurar o acesso remoto. Por meio de uma série de chamadas telefônicas, o invasor obtém o nome e endereço do servidor de acesso remoto e as credenciais de login, além de números de telefone para acesso remoto e para acessar o sistema privado de telefonia e correio de voz da organização.
- Um autor de ameaças aciona um alarme de incêndio; em seguida, entra no prédio durante a confusão e conecta um dispositivo de monitoramento a uma porta de rede.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A [[personificação]] significa simplesmente fingir ser outra pessoa. É uma das técnicas básicas de engenharia social. A falsificação de identidade é possível quando o alvo não consegue verificar a identidade do invasor facilmente, como pelo telefone ou por meio de uma mensagem de email. Um invasor normalmente usará uma das duas abordagens:

- **Persuasão/consenso/agrado:** convencer a vítima de que o pedido é natural e a recusa seria indelicada ou de alguma forma “estranha”.
- **Coerção/ameaça/urgência:** intimidar a vítima com um apelo falso à autoridade ou ameaça de penalidade, como ser demitido ou não agir com rapidez suficiente para evitar algum resultado terrível.

O clássico ataque de falsificação de identidade ocorre quando um invasor telefona para um departamento, diz que tem que ajustar alguma coisa no sistema do usuário remotamente e consegue que o usuário revele sua senha.

Figura 1. Você realmente sabe quem está do outro lado da linha?



Imagem © 123RF.com.

O uso de uma história cuidadosamente elaborada, com detalhes convincentes ou intimidadores, é denominado [[pretexting]]. Passar-se por outra pessoa de forma convincente para encantar ou intimidar uma vítima geralmente depende de o invasor obter informações privilegiadas sobre a organização. Por exemplo, quando o invasor se faz passar por um membro da equipe de suporte de TI da organização, o ataque será mais eficaz com os detalhes de identidade da pessoa que está sendo personificada e do alvo.

Algumas técnicas de engenharia social se dedicam à obtenção desse tipo de informação como atividade de reconhecimento. Como a maioria das empresas é voltada para o atendimento ao cliente, e não para a segurança, essa informação geralmente é fácil de ser obtida. Informações aparentemente inofensivas (como listas de funcionários dos departamentos, cargos, números de telefone, compromissos diários, faturas ou ordens de compra) podem ajudar um invasor a penetrar em uma organização por meio da falsificação de identidade.

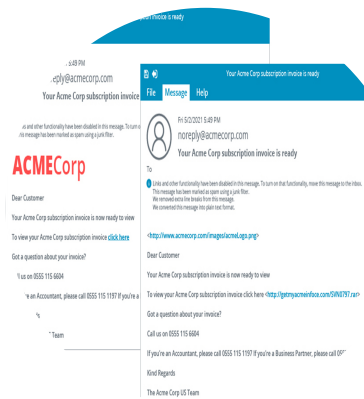


This content is only available on larger screen sizes. Please revisit this page on a larger device.

[[Phishing]] é uma combinação de engenharia social e falsificação. Ele persuade ou engana o alvo a interagir com um recurso malicioso disfarçado de confiável, tradicionalmente usando email como vetor. Uma mensagem de phishing pode tentar convencer o usuário a executar alguma ação, como instalar malware disfarçado ou permitir uma conexão de acesso remoto pelo invasor.

Outros tipos de campanha de phishing usam um site falso criado para imitar um banco ou site de comércio eletrônico ou algum outro recurso da Web que deve ser confiável para o alvo. O invasor envia um email para os usuários do site original informando que sua conta deve ser atualizada ou com algum tipo de alerta ou alarme falso, fornecendo um link disfarçado que leva, na verdade, ao site falso. Quando o usuário faz autenticação no site falso, suas credenciais de login são capturadas.

Figura 1. Exemplo de email de phishing: À direita, você pode ver a mensagem em sua forma verdadeira, pois o cliente de email retirou a formatação (mostrada à esquerda) projetada para disfarçar a natureza dos links.



Descrição

A natureza dos links da mensagem original é alterada para criar um e-mail de phishing. O e-mail de noreply arroba acmecorp ponto com é enviado na sexta-feira, 2/5/2021 às 17h49. O assunto do e-mail diz: Sua fatura de assinatura da Acme Corp está pronta.

O e-mail original possui o logotipo da ACMECorp no canto superior esquerdo, seguido de algumas linhas de texto. Há um link para visualizar sua fatura de assinatura da Acme Corp.

O e-mail de phishing apresenta um link no lugar do logotipo da ACMECorp. O link para visualizar sua fatura de assinatura da Acme Corp também foi prejudicado.

Phishing refere-se especificamente a vetores de ameaça de email ou mensagem de texto. O mesmo tipo de ataque pode ser realizado em outros tipos de mídia:

- [[Vishing]]: um ataque de phishing realizado por meio de um canal de voz (telefone ou VoIP, por exemplo). Por exemplo, os alvos podem receber ligações de alguém que diz representar o banco do qual são clientes, solicitando que eles verifiquem uma transação recente de cartão de crédito e solicitando seus detalhes de segurança. Pode ser muito mais difícil para alguém recusar uma solicitação feita em um telefonema em comparação com uma feita em um email.

Nota:

É provável que a evolução rápida da tecnologia de deep fake torne as tentativas de phishing por meio de mensagens de voz e até mesmo de vídeo predominantes no futuro.

- [[SMiShing]]: um ataque de phishing que utiliza mensagens de texto via Short Message Service (SMS) como vetor.

Mensagens diretas para um único contato têm uma alta chance de falha. Outras técnicas de engenharia social ainda usam recursos falsos, como sites falsos e páginas de login, mas dependem de redirecionamento ou métodos passivos para prender as vítimas.

Um ataque de [[pharming]] é aquele que redireciona usuários de um site legítimo para um site malicioso. Em vez de usar técnicas de engenharia social para enganar o usuário, no entanto, o pharming se baseia em corromper a maneira que o computador da vítima executa a resolução de nome na Internet de modo que a vítima seja redirecionada do site genuíno para o malicioso. Por exemplo, se mybank.foo deveria levar ao endereço IP 2.2.2.2, um ataque de pharming corrompe o processo de resolução do nome para que ele leve ao endereço IP 6.6.6.6.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Phishing e pharming dependem da falsificação de identidade para ter sucesso. A mensagem ou site falsificado deve parecer vir de uma fonte na qual o alvo confia. Um autor de ameaças pode usar várias inconsistências na maneira como a origem da mensagem é representada em um cliente de email para enganar o alvo e fazer com que ele confie na origem da mensagem.

O software cliente de email nem sempre identifica o endereço de email real usado para enviar a mensagem. Em vez disso, ele exibe um campo "De" no qual um invasor pode adicionar um valor arbitrário. Essa técnica é menos comum agora, pois o software de filtragem pode ser configurado para alertar o usuário sobre qualquer discrepância entre os

endereços do remetente real e alegado.

[[Typosquatting]] significa que o ator de ameaça registra um nome de domínio muito semelhante ao legítimo, como `exannple.com`, esperando que os usuários não percebam a diferença e assumam que estão acessando um site confiável ou recebendo e-mails de uma fonte conhecida. Eles também são chamados de domínios *cousin (primo)*, *lookalike (sósia)* ou *dopp__elganger*.

Outra técnica é registrar um subdomínio sequestrado usando o domínio principal de um provedor de nuvem confiável, como `onmicrosoft.com`. Se uma mensagem de phishing parecer vir de `example.onmicrosoft.com`, muitos usuários estarão inclinados a confiar nela.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Enquanto o phishing geralmente está associado a ataques em massa por e-mail, o [[comprometimento de e-mail corporativo]] refere-se a uma campanha sofisticada que tem como alvo um indivíduo específico dentro de uma empresa, normalmente um executivo ou gerente sênior. O autor da ameaça se apresenta como colega, parceiro de negócios ou fornecedor. É provável que o invasor realize um reconhecimento para obter uma compreensão detalhada do alvo e a melhor abordagem psicológica e pretextos para enganá-lo. É improvável que eles usem recursos óbvios de mensagens de phishing de envio em massa, como links falsificados ou anexos de arquivos de malware.

Para perpetrar esse tipo de ataque de alto risco, o invasor pode tentar primeiro obter o controle de uma conta de email legítima para enviar as mensagens de phishing.

Nota:

Algumas fontes usam o termo “comprometimento de email comercial” para um ataque com uma motivação financeira específica, no qual o objetivo é persuadir um responsável pelo orçamento a autorizar um pagamento fraudulento ou transferência bancária. Terminologia semelhante para ataques altamente direcionados inclui spear phishing (direcionado a indivíduos específicos), whaling (focado em funcionários que ocupam cargos de influência), CEO fraud (personificação do CEO) e angler phishing (utilização de mídias sociais como vetor).

Personalização de marca e desinformação

A **falsificação da marca** ocorre quando o invasor compromete recursos para duplicar com precisão os logotipos e a formatação de uma empresa (fontes, cores e estilos de cabeçalho/corpo de parágrafo) para tornar uma mensagem de phishing ou um site de pharming falsificações visualmente atraentes. O invasor pode até imitar o estilo ou o tom das comunicações por email ou copiar o site. Ele pode tentar colocar um site de phishing no topo dos resultados de pesquisa usando conteúdo realista. **Táticas de desinformação/informações falsas** podem ser usadas para criar postagens falsas nas redes sociais ou fazer referências (sites com links para o site falso) para aumentar a classificação nas buscas.

Desinformação refere-se a uma motivação intencional de enganar. Como informações falsas, entendemos a repetição de falsas alegações ou rumores sem a intenção de enganar. Uma campanha de desinformação pode tentar fazer com que os outros repitam e amplifiquem os fatos falsos que ela cria como informação errada.

Ataque Watering Hole

Um [[ataque de watering hole]] depende de um grupo de alvos que utiliza um site de terceiros não seguro. Por exemplo, a equipe que administra um site de comércio eletrônico internacional pode usar uma empresa local de entrega de pizza. Um invasor pode descobrir esse fato por meio de engenharia social ou outra técnica de reconhecimento do alvo. Um invasor pode comprometer o site da empresa de entrega de pizza para que ela execute o código de exploração nos visitantes. Ele pode ser capaz de infectar os computadores dos funcionários da empresa de comércio eletrônico e assim penetrar nos seus sistemas.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Você deve ser capaz de explicar como avaliar os tipos de autores de ameaças externos e internos em termos de intenção e capacidade. Você também deve ser capaz de resumir os vetores que compõem a superfície de ataque de uma organização.

Diretrizes para comparar autores de ameaças e superfícies de ataque

Siga estas diretrizes ao avaliar o uso de pesquisa e análise de ameaças:

- Crie um perfil de tipos de autores de ameaças que representam as ameaças mais prováveis para o seu negócio. Lembre-se de que você pode se tornar um alvo como fornecedor de uma empresa maior.
- Use a análise de fluxos de trabalho empresariais e inventários de ativos para identificar a superfície de ataque da organização.

- Use a pesquisa para ampliar a compreensão da superfície de ataque de vetores de ameaças específicos, como software vulnerável, redes não seguras, cadeias de suprimentos e ataques e iscas baseados em mensagens direcionados a vetores humanos.



This content is only available on larger screen sizes. Please revisit this page on a larger device.